# Papeles de trabajo de P1

PT-20–PT-25 · versión 1 · I6

## Índice de lectura

PT-20 · página 3

PT-21 · página 4

PT-22 · página 5

PT-23 · página 6

PT-24 · página 7

PT-25 · página 8

Solo aportes de P1. No se recibieron PT de P2/P3. Papeles_Trabajo.pdf consolidado permanece pendiente; no se reemplazan sus conclusiones.

# Papeles de trabajo P1 · I4 · versión 1

Preparación técnica: Codex, 7 de noviembre de 2026 UTC. P1/custodio designado: **Anthony Samuel Ordoñez Son, 2401002033**. Revisión humana, firma y revisión cruzada: pendientes. Corte analítico fijo: **2026-10-15T23:59:59-06:00**.

Se aplica la plantilla C de la Guía de entregables, p. 3. E-02/03/04/05/07 y alerta 08 son resúmenes del curso, no originales autenticados. Las pruebas SQL citadas fueron ejecutadas en I2/I3; en I4 se reabrieron sus archivos, se cotejaron hashes y se calcularon derivados con Python estándar, **sin ejecutar SQL nuevo**. Motor histórico: SQL Server 2022 Developer 16.0.4305.5; bases RedNova_P1_Lab_v2 y RedNova_P1_Lab_v2_repeticion; datos v2, semilla 1410. El contrato P1_Diseno_Contrato_v1 permanece como referencia vacía según el comprobante previo, sin nueva inspección del motor.

# Procedencia y método comunes

- Fuente académica: 00_Material_del_curso/Proyecto_Operacion_Trazabilidad_Auditoria_Sistemas.pdf, pp. 3–5. Hash y versión en resultados/I4/Verificacion_entradas_I4_v1.json. Fecha histórica de extracción, custodios y hashes de los sistemas del incidente: no aportados.

- Fuentes de laboratorio: 04_SQL/datos/v2/, manifiesto y Laboratorio_v1.json; resultados originales conservados en resultados/I2_I3_verificacion_cierre/ y repetición en resultados/I2_I3_repeticion/. resultados/Ejecuciones_v1.csv registra momentos UTC exactos del 7 de noviembre, login, consulta, corte y hashes; no son horas de ocurrencia del incidente.

- Obtención: carga/SELECT/exportación en I2/I3; lectura local de CSV/JSON y hashlib.sha256 en I4. Custodia efectiva de copias en formulario_custodia.md; custodio designado arriba, operador Codex, sin firma humana. Primeras versiones previas a I4 conservadas en originales/previos_I4/.

- Reproducción del análisis: python3 03_Evidencias/analizar_I4.py desde la raíz del proyecto. Coteja 305 entradas (incluye repeticiones entre registros), los 13 registros de ejecución y los CSV Q; deja comprobantes en resultados/I4/. Para repetir SQL, usar 04_SQL/README.md, sin exponer .env ni .env.auditor.

- Riesgos y controles globales R/C: pendientes de P2. Se emplean referencias descriptivas provisionales en cada PT, sin asignar códigos R/C ajenos. Los umbrales de S-P1-UMB son reglas de laboratorio, no políticas de RedNova. El criterio externo voluntario está delimitado en ../07_Referencias/Fuentes_P1_v1.md; no acredita obligatoriedad contractual o legal.

# PT-20 · E-02 · sesión remota y MFA

**Objetivo.** Contrastar autenticación y horario de la sesión reportada de ext_ops_04; determinar si puede concluirse uso indebido o infracción de política.

**Vínculos.** Riesgo provisional: uso indebido de acceso externo; control provisional: autenticación y revisión de accesos (P2). T-21/Q-02, T-22/Q-03, T-31/Q-12, T-33; E-02 y E-13/E-14/E-23/E-25. Supuestos S-03, S-P1-ACC/NOR/UMB.

**Fuente / fecha / custodio.** Fuente común; expediente pp. 4–5, evento EVT-02 del 14 de octubre, 02:17. Q-02/Q-03 y Usuarios.csv/Sesiones.csv, obtenidos y custodiados según el método común.

**Procedimiento ejecutado / muestra.** I3: Q-02 revisó las 120 cuentas, con 30 privilegiadas diseñadas; Q-03 usó referencia por cuenta del 7–13 de octubre (>=5 observaciones en >=3 días) y seleccionó actividad posterior fuera de sus horas. Noches habituales de soporte/servicio sirvieron de contraste. I4: cotejo íntegro de hashes/CSV, reapertura de los 18 resultados Q-02 y tres Q-03; identificación de ext_ops_04 y cotejo con EVT-02. Se consultó el expediente para buscar política y excepciones; no se aportaron.

**Resultado y límites.** Q-02: 18 cuentas sintéticas seleccionadas (ocho sin MFA, cuatro compartidas, tres recertificaciones >180 días y tres sin fecha), incluyendo ext_ops_04. Q-03: tres sesiones seleccionadas, una reproduce E-02 y dos son controles anómalos; no equivale a tres sesiones del ataque. El expediente sí reporta sesión sin MFA, pero no entrega configuración, excepciones, dispositivo, titular humano ni registro original. El estado y privilegio de la cuenta en el CSV son supuestos.

**Conclusión. No concluyente** sobre incumplimiento de MFA o uso malicioso real. La selección del laboratorio es reproducible y distingue controles; no demuestra quién usó la cuenta. Solicitar configuración histórica IdP/VPN, política aplicable, excepciones, sesión/token y trazas del equipo. La evaluación final de accesos corresponde a P2.

# PT-21 · E-03 · lectura y elevación

**Objetivo.** Evaluar el volumen de lectura contra su propia base y sus privilegios históricos, conservando atribuciones desconocidas.

**Vínculos.** Riesgo provisional: lectura no autorizada; control provisional: mínimo privilegio/trazabilidad de consultas (P2). T-23/Q-04, T-24/Q-05, T-31/Q-12; E-03, E-15/E-16/E-23. S-P1-CAS/NOR/UMB, S-03.

**Fuente / fecha / custodio.** Fuente común; expediente p. 4, elevación 02:26 y lectura 02:31; p. 5 E-03. Privilegios.csv, BitacoraSQL.csv, Q-04/Q-05. Custodia y fechas de producción según registro común.

**Procedimiento ejecutado / muestra.** I3: Q-04 seleccionó asignaciones vigentes al corte con ticket/vencimiento ausente; Q-05 contrastó lectura >3× máximo por cuenta con >=5 días de referencia, sin imputar identidad. I4: lectura de las siete asignaciones seleccionadas y dos lecturas seleccionadas; cotejo de 31,840 con EVT-04 y preservación de nulos; comparación por serialización descrita en PT-22.

**Resultado y límites.** Q-04: seis casos de control incompletos y una reproducción de elevación sin cuenta/rol/ticket/vencimiento aportados. Q-05: lectura de control de 20,000 frente a 1,000 máximo; la de **31,840** queda **no evaluable** por falta de login/base. No hay vínculo de sesión, IP o token que una ext_ops_04, la elevación y la lectura. Cinco minutos entre elevación y lectura no prueban ese vínculo. Ni un rol registrado prueba permiso efectivo histórico.

**Conclusión. No concluyente** sobre exceso o autorización de la lectura del incidente y su responsable. Solicitar auditoría SQL original, sentencia, resultado/objeto, login/sesión/aplicación, permisos efectivos al momento y registros correlacionables de identidad. El resultado positivo del control valida la regla, no la hipótesis de ataque.

# PT-22 · E-04 · transferencia y orden de magnitud

**Objetivo.** Caracterizar el flujo reportado y determinar qué falta para sostener extracción de clientes.

**Vínculos.** Riesgo provisional: salida de datos sin autorización; control provisional: identificación y monitoreo de flujos. T-25/Q-06, T-24/Q-05, T-31/Q-12; E-04, E-16/E-17/E-23/E-26/E-28.

**Fuente / fecha / custodio.** Fuente común; expediente pp. 4–5, 02:35 del 14 de octubre. Q-06/TransferenciasRed.csv, diccionario y Clientes.csv v2; cálculo nuevo resultados/I4/Volumen_31840_I4_v1.json.

**Procedimiento ejecutado / muestra.** I3: Q-06 comparó por origen/destino/protocolo/puerto con >=5 días y >3×; incluyó campos no evaluables. I4: lectura de tres resultados; selección determinista de los primeros 31,840 ClienteID sintéticos y siete campos comerciales del diccionario, serializados en memoria como CSV y JSONL UTF-8; cálculo de bytes y cocientes, sin escribir un supuesto paquete exfiltrado.

**Resultado y límites.** E-04 conserva BytesEnviados NULL, sin IP, puerto, protocolo, duración ni clasificación. Los otros dos flujos son controles: 1,200,000,000 bytes supera su base y otro carece de clasificación. Modelo CSV: **2,058,909 bytes**; JSONL: **5,115,483 bytes**. Frente a 1.6×10^9 bytes son factores **777.11** y **312.78**. Si «GB» se hubiese usado por GiB, 1.6×2^30 es una alternativa hipotética (1,717,986,918.4 bytes matemáticos, no conteo real) y los factores son 834.42 y 335.84. Formato, campos, nulos, hash de serializaciones y escenarios 1,000/10,000/50,000 bytes por fila constan en el JSON. Sin compresión, adjuntos ni sobrecarga de transporte; el esquema de producción no fue aportado. Los cuatro minutos entre lectura y flujo no dan la duración de envío ni una tasa.

**Conclusión. No concluyente** sobre exfiltración o correspondencia de ambas cifras. Un envío único con estos siete campos sintéticos queda muy por debajo de ~1.6 GB; eso no descarta archivos, repeticiones, otros datos o tráfico legítimo y no confirma ninguno. Solicitar flujos/proxy/cloud originales, identidad del destino, equipo/proceso, objetos transferidos y autorización; contrastarlos con auditoría SQL y patrón habitual real.

# PT-23 · E-05 · órdenes, duplicidad y respaldo

**Objetivo.** Distinguir órdenes de cambios, determinar campos/atribución disponibles y la posibilidad de contrastar con respaldo y facturación.

**Vínculos.** Riesgo provisional: alteración de órdenes y diferencias de integridad; control provisional: trazabilidad/conciliación. T-26/Q-07, T-27/Q-08, T-28/Q-09, T-31/Q-12; E-05/E-08, E-18/E-19/E-20/E-23/E-26. S-P1-ORD y S-04.

**Fuente / fecha / custodio.** Fuente común; E-05 pp. 4–5 reporta 216 órdenes a las 02:42; Q-07 y HistorialOrdenes.csv v2, Q-08/Q-09. Nuevos cotejos en resultados/I4/Analisis_ordenes_I4_v1.json.

**Procedimiento ejecutado / muestra.** I3: Q-07 exportó toda la ventana inclusiva 02:17–03:42; Q-08 agrupó cliente/minuto/plan/monto/canal y excluyó canceladas; Q-09 separó programación/ejecución/restauración. I4: se cotejaron **las 216 filas y todos los campos comunes** con el historial fuente mediante Python, se contaron CambioID/OrdenID distintos, campos y nulos; se cruzaron IDs de candidatos a duplicidad. Muestra explicable, aún sin revisión humana: CambioID=1, OrdenID=1, ClaseOrigen=laboratorio, S-P1-ORD; sus valores 200.00→220.00 GTQ son ficticios.

**Resultado y límites. 216 cambios/216 órdenes distintas; 144 de monto y 72 de estado**, todos a las 02:42 por diseño; estado sintético Pendiente→Confirmada. Las 216 filas carecen de UsuarioID, SesionID y Via; los valores/campos no proceden del expediente. Q-08: diez pares/20 órdenes candidatas (1001–1020), **sin intersección** con las 216; no son doble cobro probado ni parte demostrada del incidente. No hay facturas, cobros, autorizaciones ni copia de producción anterior para conciliar. Q-09: nueve programaciones, ocho con ejecución dentro del 7–14, ninguna registrada el 15; 3.2 frente a 8.2 GiB (−60.976 %) en registros sintéticos. La novena ejecución del conjunto es histórica de junio. El 1 de julio y 106 días al corte son un registro de restauración **ficticio**, no restore ejecutado ni prueba de recuperación real.

**Conclusión. No concluyente** sobre integridad, fraude, atribución y pérdida económica; la afirmación «datos intactos» tampoco queda acreditada. El conteo reproduce E-05 y verifica la consulta. Solicitar historial anterior/posterior autenticado, request/transaction ID, sesiones/API/scripts, autorizaciones y conciliación con ERP/facturas y respaldo validado. No se sumaron montos ficticios ni se extrapolaron pérdidas. P3 debe aportar BIA/RTO/RPO antes de evaluar recuperación.

# PT-24 · E-07 · seguimiento de alerta

**Objetivo.** Evaluar detección, asignación, primera acción, escalamiento y cierre documentados sin imponer SLA inexistente.

**Vínculos.** Riesgo provisional: atención no trazable de alertas; control provisional: flujo de seguimiento. T-30/Q-11, T-31/Q-12; E-07, E-22/E-23. Criterio académico y externo: CR-I4-01 en Fuentes_P1; borrador relacionado B1-1.

**Fuente / fecha / custodio.** Fuente común; expediente p. 4 EVT-08, 03:18, y p. 5 E-07 sin cierre documentado; Alertas.csv, Q-11 y resultados/I4/Intervalos_I4_v1.json.

**Procedimiento ejecutado / muestra.** I3: selección de faltantes entre seis alertas; intervalos solo con extremos presentes. I4: reapertura de las cuatro seleccionadas; cotejo contra cronología y recálculo de intervalos reportados. Se buscó en los materiales disponibles asignación, primera acción y cierre del caso; no se aportaron.

**Resultado y límites.** Q-11 contiene tres controles incompletos y una reproducción del caso (AlertaID=6), sin asignado, primera acción, cierre ni nota. Desde sesión remota a alerta: **61 min**; alerta a caída: **24 min**; caída a solicitud DR: **23 min**. El primero mide distancia entre marcas, no tiempo probado desde intrusión ni ausencia de detección previa. No se puede medir tiempo de atención/cierre ni asumir que 04:05 fue la primera acción de seguridad. No hay evidencia de inacción por 24 min.

**Conclusión. No concluyente** sobre operación real del seguimiento. Sí está documentada la insuficiencia del expediente para acreditar cierre. Solicitar ticket SIEM, recepción/asignación, acciones, escalamiento y aceptación del cierre; fijar objetivos con administración/P2 y probar el circuito. Ver B1-1, sin asignación de H definitivo.

# PT-25 · alerta 08 · integridad de registros

**Objetivo.** Examinar posibilidad de modificar registros, fiabilidad temporal, cobertura y límites de preservación.

**Vínculos.** Riesgo provisional: pérdida o alteración de registros; control provisional: acceso segregado, copia protegida y trazabilidad. T-32/Q-S01, T-31/Q-12, T-33; alerta 08 (proyecto p. 3), E-23/E-24/E-25/E-26 y FuentesTiempo.csv. CR-I4-02; borrador relacionado B1-2.

**Fuente / fecha / custodio.** Fuente común; Q-S01.csv, Concesiones_SQL.csv, Permisos_rechazos.csv, Conexion_auditor.json; comprobación ejecutada en I3 con contexto explícito y momento en Ejecuciones. Cronología/tabla de relojes son transcripción/supuestos, no logs de producción.

**Procedimiento ejecutado / muestra.** I3: HAS_PERMS_BY_NAME bajo EXECUTE AS USER para dos usuarios ficticios (ejecutor sa) y conexión propia de auditor_lectura; cinco intentos del auditor rechazados. No se ejecutó UPDATE/DELETE de bitácora. I4: relectura de los tres contextos/cinco rechazos, hashes y concordancia de ejecuciones; inspección de los 13 eventos, relojes y sus intervalos; escenarios de offsets independientes ±5/10/15 min y offset común constante para marcas CRM.

**Resultado y límites.** admin_bitacora_lab: SELECT/UPDATE/DELETE=1, ALTER/CONTROL BD=0; control_bitacora_lab y auditor_lectura: solo SELECT entre esos permisos. LoginConexion=sa en los dos primeros identifica al ejecutor, no al titular real investigado; NULL de ControlServidor no permite evaluarlo en esos contextos. Los cinco rechazos del auditor (229 en INSERT/UPDATE/DELETE, 1088 ALTER y 15247 administración) no demuestran ausencia de otros administradores. Los 13 eventos no tienen original/zona/desfase comprobado; solo EVT-02 tiene cuenta. La cronología no es una secuencia exhaustiva de logs: sus intervalos, incluido el de 24 min, son **vacíos de información**, no lagunas técnicas probadas. Sin secuencias, contadores, retención y duplicado independiente no puede medirse pérdida de logs. Desfase real sin cota; escenarios en resultados/I4/Sensibilidad_relojes_I4_v1.csv.

**Conclusión. No concluyente** sobre alteración, permisos o preservación en RedNova. La capacidad efectiva de modificación sí quedó comprobada exclusivamente para el administrador ficticio; no se probó modificación. Se recomienda copia independiente protegida y revisión de permisos/retención/relojes, con pruebas reales autorizadas de generación y rechazo de modificación sobre un entorno de control. Solicitar originales, ACL históricas, colector independiente y marcas compartidas para estimar offsets; ver B1-2.

# Explicación y revisión pendientes de P1

P1 debe seguir CambioID=1 desde PT-23 a Q-07 y al CSV v2, explicar por qué no implica Q20.00 de pérdida real y contrastarlo en SQL como auditor cuando realice su revisión. Debe defender una hipótesis del informe, explicar el resultado no concluyente de PT-22 y mostrar qué original cambiaría B1-1/B1-2. Esta muestra se preparó; no se realizó entrevista, ensayo, revisión humana ni traspaso.